Reporte de Actividades Prácticas-Experimentales Nro. 001

1. Datos Generales

Asignatura	Software Security
Ciclo	8 A
Unidad	1
Resultado de Aprendizaje de la Unidad	R1. Diseña e implementa software bajo los principios básicos de estándares seguros, en el marco de los principios de solidaridad, transparencia, responsabilidad y honestidad.
Práctica Nro.	1 (Fases 1 a 4)
Título	Análisis y superficie de ataque del proyecto
Docente	Valeria Herrera Salazar
Período	Del 28 de septiembre al 23 de octubre de 2026 (Semanas 1 a 4)
Horario	Jueves: 09h30 – 11h30 Viernes: 07h30 – 09h30
Lugar	Aula de Clase
Tiempo planificado	16 horas (4 horas por semana)
Integrantes:	• Walter Yaguana • Cristian Ajila • Santiago Abrigo

2. Objetivo(s) de la Práctica:

La primera guía inicia el proyecto integrador que acompañará a toda la asignatura: cada estudiante o pareja de trabajo selecciona la aplicación que auditará durante las dieciséis semanas y construye, sobre ella, la línea base de seguridad del proyecto. Cada fase responde de manera directa al contenido teórico tratado en las horas de contacto con el docente de esa misma semana.

- Seleccionar la aplicación que se auditará durante las dieciséis semanas del ciclo (un proyecto propio de asignaturas anteriores o un entorno controlado como DVWA u OWASP Juice Shop).
- Delimitar la superficie de ataque de la aplicación y elaborar el inventario inicial de elementos expuestos.
- Aplicar la tríada CIA (confidencialidad, integridad y disponibilidad) para clasificar los activos y las amenazas del proyecto.
- Revisar la gestión de errores y excepciones, detectando las fugas de información en mensajes y trazas de la aplicación.
- Evaluar la aplicación frente al OWASP Top 10 y elaborar la matriz de priorización de hallazgos que servirá de insumo directo para la auditoría técnica de la guía APE 02.

3. Materiales y reactivos:

Los recursos necesarios para esta guía están disponibles en la infraestructura institucional y en herramientas de libre acceso. El docente publicará en el EVA, con anticipación a cada semana, las plantillas de registro correspondientes a cada fase.

- Ordenador personal con acceso a internet y navegador web actualizado.
- Cuenta activa en GitHub u otra plataforma similar para el repositorio de evidencias del proyecto (una cuenta por pareja o por estudiante).
- Aplicación objetivo: proyecto propio de asignaturas previas (con código disponible, ejecución local, autenticación y base de datos) o entorno controlado (DVWA u OWASP Juice Shop) instalado en una máquina virtual.
- Plantillas del EVA: ficha del proyecto, inventario de superficie de ataque, matriz de activos y amenazas, registro de gestión de errores y lista de cotejo OWASP Top 10.
- Material de consulta: la entrada oficial del OWASP Top 10 y los documentos de clase de las semanas 1 a 4.

4. Equipos y herramientas:

- Aula física con equipamiento audiovisual.
- Computadoras personales o dispositivos móviles de los estudiantes.
- Entorno Virtual de Aprendizaje (EVA) de la UNL.
- Repositorio GitHub del proyecto para el portafolio de evidencias.
- Software de hojas de cálculo (Excel/Google Sheets) para la matriz de activos y amenazas y para la matriz de priorización de hallazgos.
- Procesador de texto para la redacción de los informes de cada fase.

5. Procedimiento / Metodología:

Fase 1 (Semana 1 - del 28 de septiembre al 02 de octubre de 2026): Encuadre del componente práctico y selección de la aplicación objetivo

Sesión 1 (jueves 01 de octubre, 09h30 a 11h30): Organización y exploración de candidatos

Actividad 1: Socialización de la organización del componente APE (25 minutos)

El docente presenta la organización del componente práctico experimental: las cuatro guías del ciclo, sus fases, los entregables, las rúbricas y su incidencia en la calificación del componente. Se socializa además el cronograma de las dieciséis semanas y el enfoque de proyecto integrador continuo que acompaña a toda la asignatura.

Actividad 2: Diagnóstico práctico inicial (20 minutos)

Los estudiantes resuelven un cuestionario breve e individual sobre conceptos fundamentales de seguridad (tríada CIA, tipos de vulnerabilidades y superficies de exposición), aplicado mediante una actividad del EVA. Los resultados permiten al docente identificar los conceptos que requerirán refuerzo durante la unidad.

Actividad 3: Exploración de candidatos a aplicación objetivo (45 minutos)

3.1. Aplicación seleccionada

Nombre: Active Gym

Tipo: Aplicación web
Área de aplicación: Gestión administrativa de gimnasios

3.2. Descripción del sistema

ActiveGym es un sistema web desarrollado para facilitar la administración de un gimnasio mediante herramientas digitales que permiten organizar y controlar diferentes procesos.

3.3. Justificación de la selección

Se seleccionó ActiveGym porque es una aplicación que maneja información relacionada con usuarios, credenciales y procesos administrativos.

Los módulos de autenticación y usuarios resultan relevantes para una auditoría de seguridad, debido a que permiten controlar el acceso al sistema y administrar la información de los usuarios.

Una vulnerabilidad en estos componentes podría comprometer la confidencialidad, integridad o disponibilidad de los datos.

Actividad 4: Registro del proyecto (30 minutos)

4.1. Tipos de usuarios

Administrador: usuario encargado de gestionar las funcionalidades administrativas del sistema, según los permisos implementados.

Entrenador: usuario que accede a las funcionalidades autorizadas de acuerdo con su rol.

4.2. Tecnologías utilizadas

Frontend: Next JS.

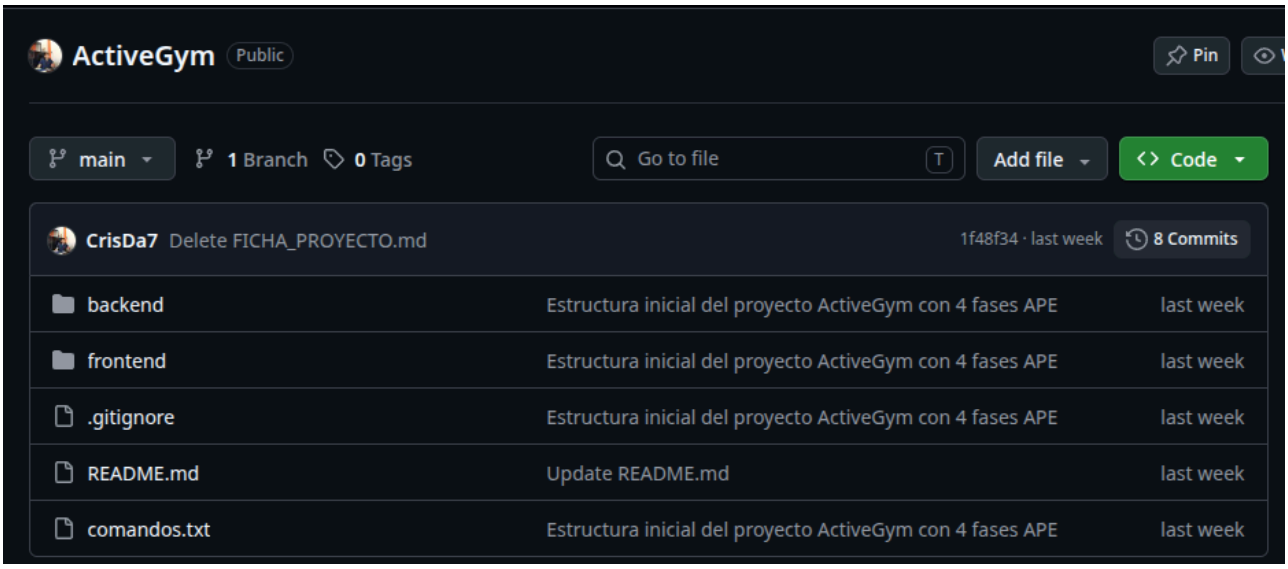
Backend: Flask.

Base de datos: PostgreSQL.

4.5. Repositorio del proyecto

El proyecto ActiveGym dispone de un repositorio en GitHub, en el cual se encuentra organizado el código fuente.

Evidencia 1: Captura del repositorio ActiveGym en GitHub.



Sesión 2 (viernes 02 de octubre, 07h30 a 09h30): Puesta en marcha e inventario inicial

Actividad 1: Confirmación de criterios y alcance (15 minutos)

1.1. Alcance de la auditoría

El análisis de seguridad de ActiveGym estará enfocado en los siguientes módulos:

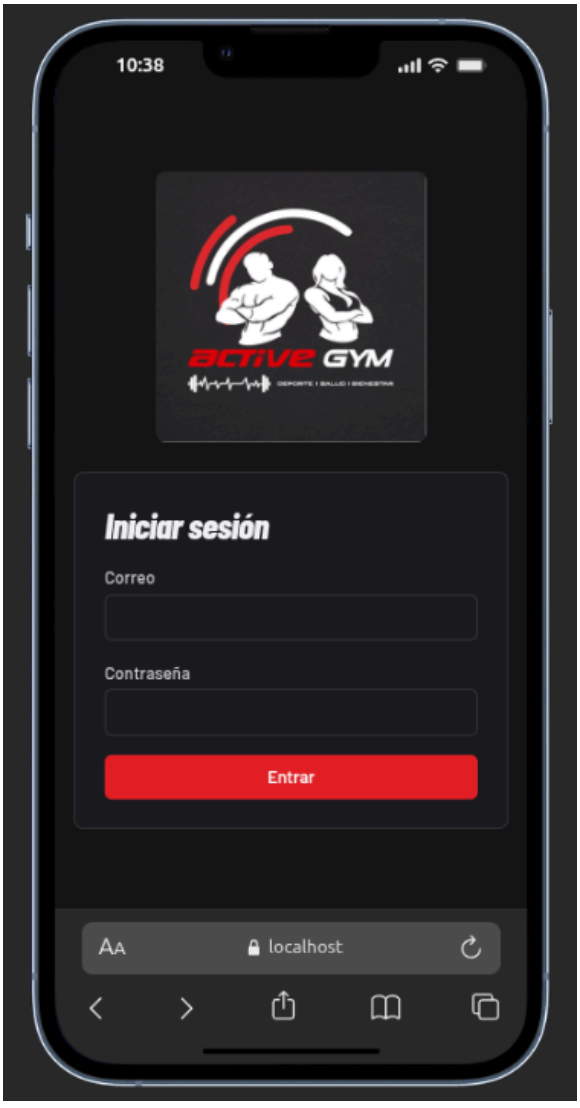
Módulo de autenticación

Se analizarán los mecanismos relacionados con el inicio de sesión, la validación de credenciales y el control de acceso a las funcionalidades protegidas.

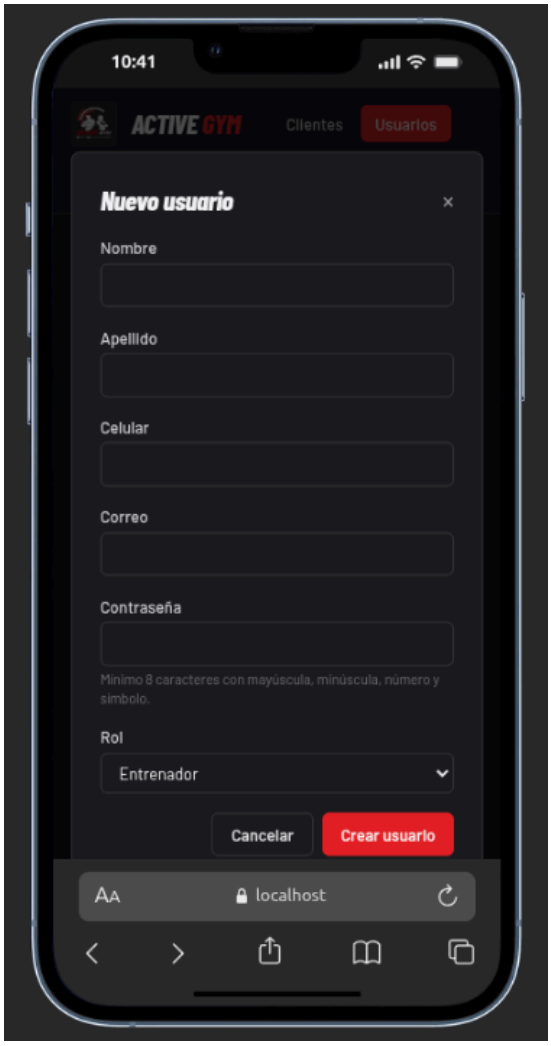
Módulo de usuarios

Se analizarán las funcionalidades de gestión de usuarios y los controles utilizados para proteger sus datos y restringir las operaciones según los permisos asignados.

Evidencia 2: Captura del módulo de autenticación.



Evidencia 3: Captura del módulo de usuarios.



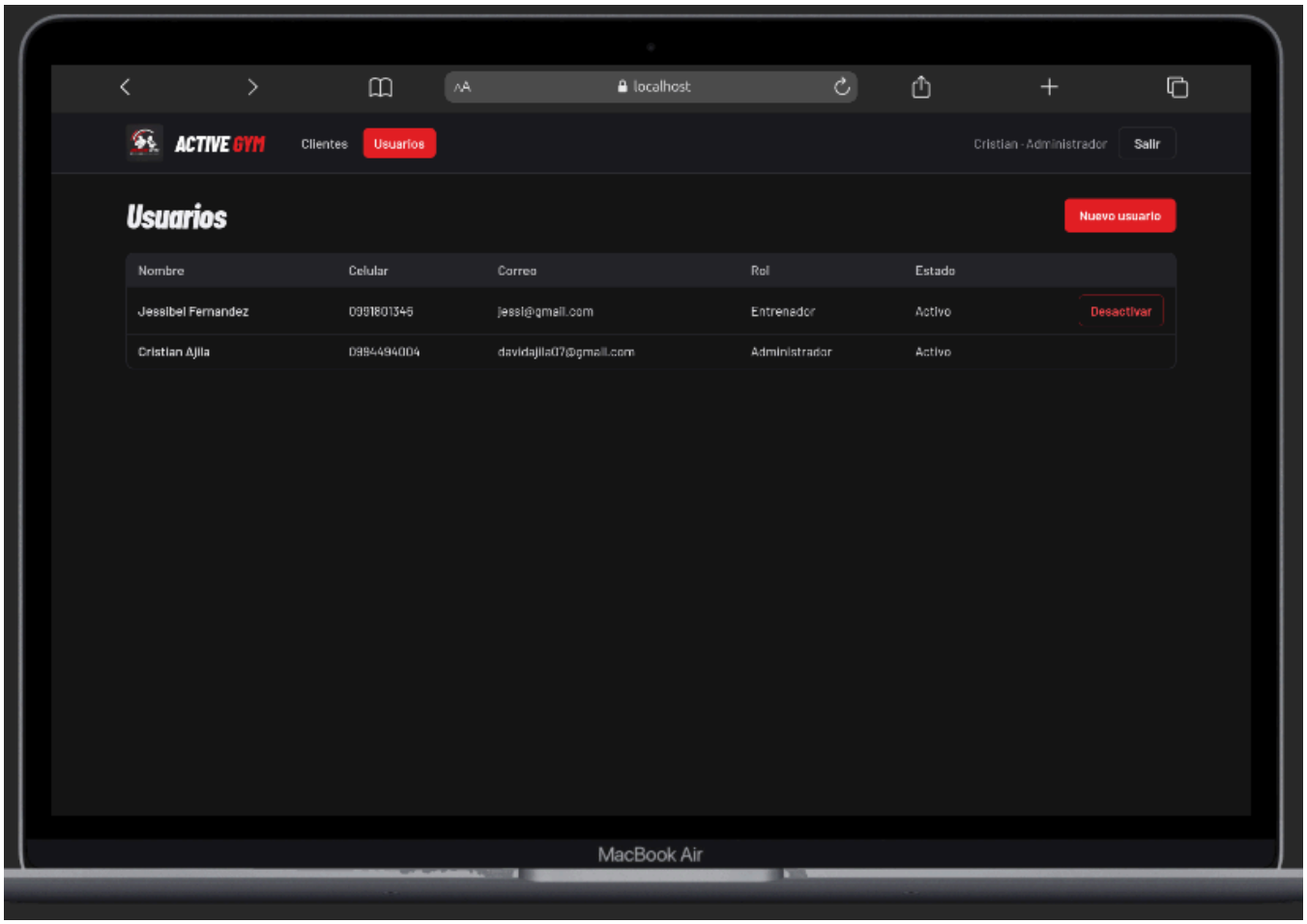
Actividad 2: Puesta en marcha del entorno (40 minutos)

2.1. Entorno de trabajo

Para realizar las actividades de auditoría se utilizará un entorno controlado de ejecución de ActiveGym.

El sistema cuenta con una estructura dividida en frontend y backend, que permite identificar los componentes de interfaz y servidor.

Evidencia 4: Captura de ActiveGym ejecutándose en el entorno local.



Actividad 3: Inventario inicial de la superficie de ataque (45 minutos)

La superficie de ataque comprende los puntos de interacción con la aplicación que podrían presentar vulnerabilidades de seguridad.

Para ActiveGym se identifican inicialmente los siguientes elementos que deben verificarse:

ID	Elemento	Módulo	Riesgo potencial
SA-01	Formulario de inicio de sesión	autenticación	acceso no autorizado
SA-02	campo de correo electrónico	autenticación	validación insuficiente de entradas
SA-03	campo de contraseña	autenticación	exposición de credenciales
SA-04	funciones de	usuarios	modificación no

	gestión de usuarios		autorizada
SA-05	endponits de autenticación y usuarios	backend	acceso indebido a recursos
SA-06	mecanismo de session	autenticación	uso indebido de sesiones

Actividad 4: Cierre y consolidación (20 minutos)

En esta fase se estableció ActiveGym como aplicación objetivo y se delimitó el alcance de la auditoría a los módulos de autenticación y usuarios.

Asimismo, se describieron sus funcionalidades principales, se identificó la estructura general del repositorio y se elaboró un inventario preliminar de los elementos que conforman su superficie de ataque.

Los resultados servirán como base para la identificación de activos, amenazas y controles de seguridad en la siguiente fase.

Fase 2 (Semana 2 - del 05 al 09 de octubre de 2026): Tríada CIA y matriz de activos y amenazas

Sesión 1 (jueves 08 de octubre, 09h30 a 11h30): Activos de información y clasificación CIA

Actividad 1: Repaso aplicado de la tríada CIA (20 minutos)

La tríada CIA constituye uno de los fundamentos de la seguridad de la información y está formada por tres principios:

1.1. Confidencialidad

Consiste en garantizar que la información sea accesible únicamente para usuarios autorizados.

En ActiveGym, este principio es importante para proteger las credenciales de inicio de sesión y los datos personales de los usuarios.

1.2. Integridad

Busca garantizar que la información se mantenga correcta y que no sea modificada sin autorización.

En ActiveGym, permite proteger los datos de usuarios, sus roles y la información almacenada en la base de datos.

1.3. Disponibilidad

Garantiza que los servicios y la información puedan ser utilizados por los usuarios autorizados cuando los necesiten.

En ActiveGym, es importante para mantener operativo el inicio de sesión y permitir el acceso a las funcionalidades del sistema.

1.4. Defensa en profundidad

La defensa en profundidad consiste en implementar diferentes capas de seguridad para proteger un sistema.

En ActiveGym, estas capas pueden incluir autenticación, autorización, validación de entradas, protección de credenciales y mecanismos de respaldo.

Actividad 2: Construcción de la matriz de activos (70 minutos)

2.1. Identificación de activos

Se propone el siguiente inventario de activos relacionados con los módulos seleccionados:

ID	Activo	Tipo
A01	CRedenciales de inicio de sesión	credenciales
A02	información de usuarios y roles	datos almacenados
A03	base de datos de usuarios	datos almacenados
A04	servicio de autenticación	servicio
A05	información de sesión	datos de sesión
A06	servicio de gestión de usuarios	servicio

2.2. Matriz de clasificación CIA

Se utilizarán tres niveles de importancia:

- **Alta:** su compromiso puede afectar significativamente la seguridad o el funcionamiento del sistema.
- **Media:** su compromiso puede generar afectaciones moderadas.
- **Baja:** su compromiso tiene consecuencias limitadas.

La siguiente matriz presenta una clasificación inicial propuesta para ActiveGym:

activo	confidencialidad	integridad	disponibilidad
A01.Credenciales	Alta	Alta	media
A02.Usuarios y roles	Alta	Alta	media

A03.Base de datos	Alta	Alta	Alta
A04.Autenticación	Alta	Alta	Alta
A05.Sesiones	Alta	Alta	media
A06.Gestion de usuarios	Alta	Alta	media

2.4. Matriz de activos y amenazas

activo	activo	amenaza identificada	consecuencia potencial
A01.	Credenciales	robo o exposición de contraseñas	acceso no autorizado
A02.	Usuarios y roles	medificacion inhibida de permisos	escalamiento de privilegios
A03.	Base de datos	acceso no autorizado o pérdida de información	exposición o pérdida de datos
A04.	Autenticación	intentos automatizados de acceso	compromisos de cuentas
A05.	Sesiones	robo o reutilización de tokens de sesión	suplantación de usuarios
A06.	Gestion de usuarios	falta de validación de permisos	modificación no autorizada de usuarios

Actividad 3: Revisión entre pares (30 minutos)

Las parejas intercambian sus matrices y elaboran retroalimentación escrita sobre activos faltantes o clasificaciones discutibles, que se incorpora al documento antes del cierre de la sesión.

Sesión 2 (viernes 09 de octubre, 07h30 a 09h30): Controles y priorización

Actividad 1: Defensa en profundidad (25 minutos)

1.1. Identificación de capas de seguridad

Para evaluar la defensa en profundidad de ActiveGym se consideran las siguientes capas:

capa de seguridad	funcion	estado de verificación
autenticación	verificar la identidad de los usuarios	formulario identificado, mecanismo pendiente de revisar
autorización	restringir operación según roles	pendiente de verificar
validación de entradas	evitar el procesamiento de datos inválidos	pendiente de verificar
protección de contraseñas	evitar la exposición de credenciales	pendiente de verificar
protección de sesiones	evitar el uso indebido	pendiente de verificar
respaldos	facilitar la recuperacion de informacion	pendiente de verificar

Actividad 2: Propuesta de controles de mitigación (65 minutos)

Se consideran prioritarios los activos cuya exposición, modificación o indisponibilidad podría comprometer el acceso al sistema o la información de los usuarios.

2.1. Matriz de controles de mitigación

activo crítico	control 1	control 2
A01.Credenciales	almacenamiento mediante hash seguro de contraseñas	limitación de intentos de inicio de sesión
A02.Usuarios y roles	control de acceso basado en roles	validación de permisos en el backend
A03.Base de datos	restricción de permisos de acceso	respaldo periódicos y pruebas de restauración
A04.Autenticación	validación segura de credenciales	registro y monitoreo de intentos de acceso
A05.Sesiones	cookies seguras o protección equivalentes de tokens	expiración y revocación de sesiones
A06.Gestion de usuarios	autorización en cada operación	validación de datos en el servidor

Actividad 3: Informe de la fase (30 minutos)

El análisis de activos y amenazas permite reconocer la importancia de proteger los componentes relacionados con la autenticación y la administración de usuarios de ActiveGym.

La aplicación de la tríada CIA facilitó la clasificación de los activos según sus necesidades de protección, mientras que la identificación de amenazas permitió establecer posibles escenarios de riesgo.

Finalmente, se propusieron controles de mitigación basados en la defensa en profundidad, orientados a fortalecer la seguridad de la aplicación.

Para completar la evaluación será necesario verificar los controles implementados y documentar las evidencias correspondientes.

Fase 3 (Semana 3 - del 12 al 16 de octubre de 2026): Gestión de errores y fugas de

información

Sesión 1 (jueves 15 de octubre, 09h30 a 11h30): Provocación controlada de errores

Actividad 1: Marco conceptual (20 minutos)

El docente explica qué información sensible revelan los mensajes de error (trazas de pila, versiones de componentes, rutas de archivos y consultas) y por qué estas revelaciones constituyen una fuga de información utilizable por un atacante.

Actividad 2: Laboratorio de provocación de errores (80 minutos)

Cada pareja provoca de forma controlada al menos cinco errores en su aplicación (credenciales inválidas, parámetros alterados, recursos inexistentes, formularios incompletos y subida de archivos fallida) y registra en la plantilla la información expuesta en cada caso, con captura de pantalla como evidencia.

Actividad 3: Sistematización de hallazgos (20 minutos)

Consolidación de las fugas detectadas en el registro de la fase y preparación de la clasificación que se realizará en la siguiente sesión.

1. A01 — Control de acceso roto

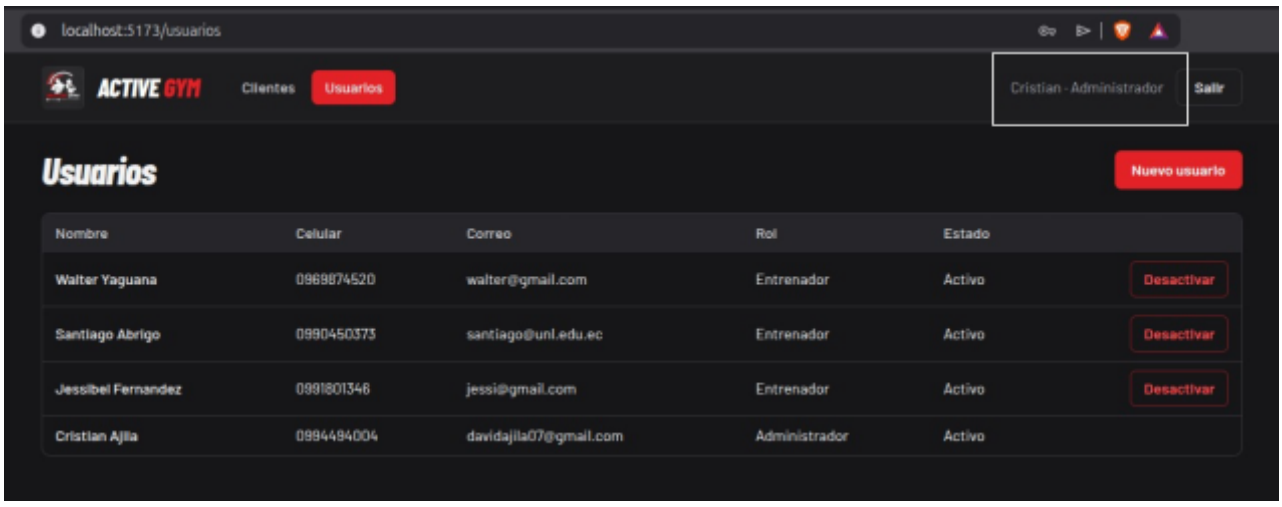
Prioridad alta

Objetivo: comprobar que cada usuario solo pueda acceder a las funciones autorizadas.

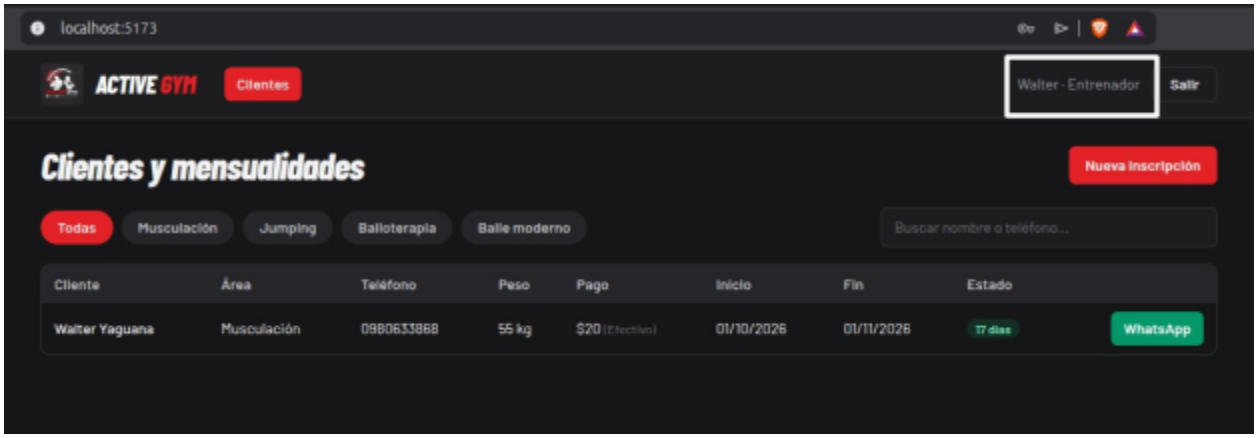
Prueba: iniciar sesión como usuario normal e intentar acceder a una ruta exclusiva del administrador.

Resultado esperado: el sistema deniega el acceso.

Aquí estamos dentro del panel de administrador



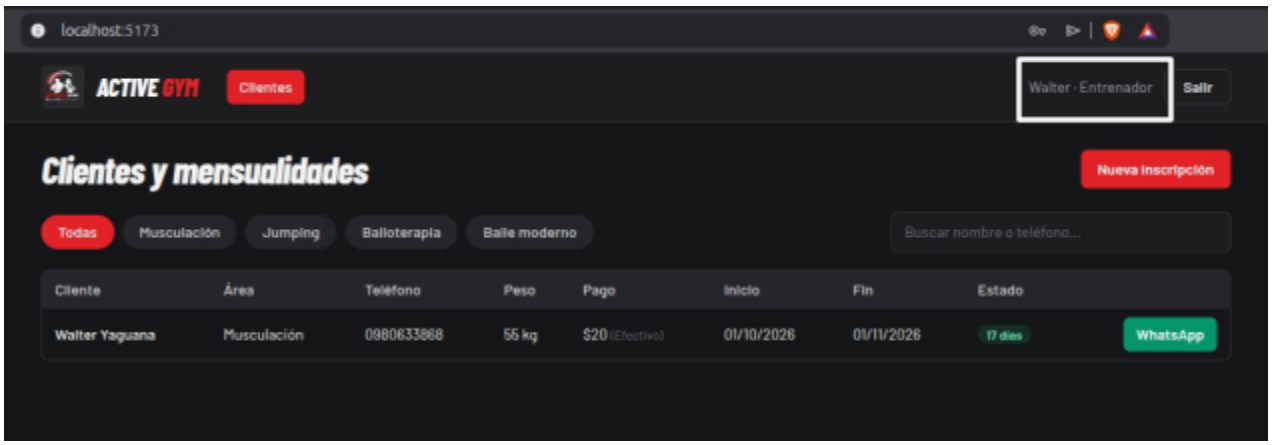
Estamos dentro del panel del entrenador



Intentamos ingresar desde el panel de entrenador a la URL de usuarios del administrador



No se pudo acceder al Panel de usuarios por lo tanto nos redirigió al panel de Entrenador



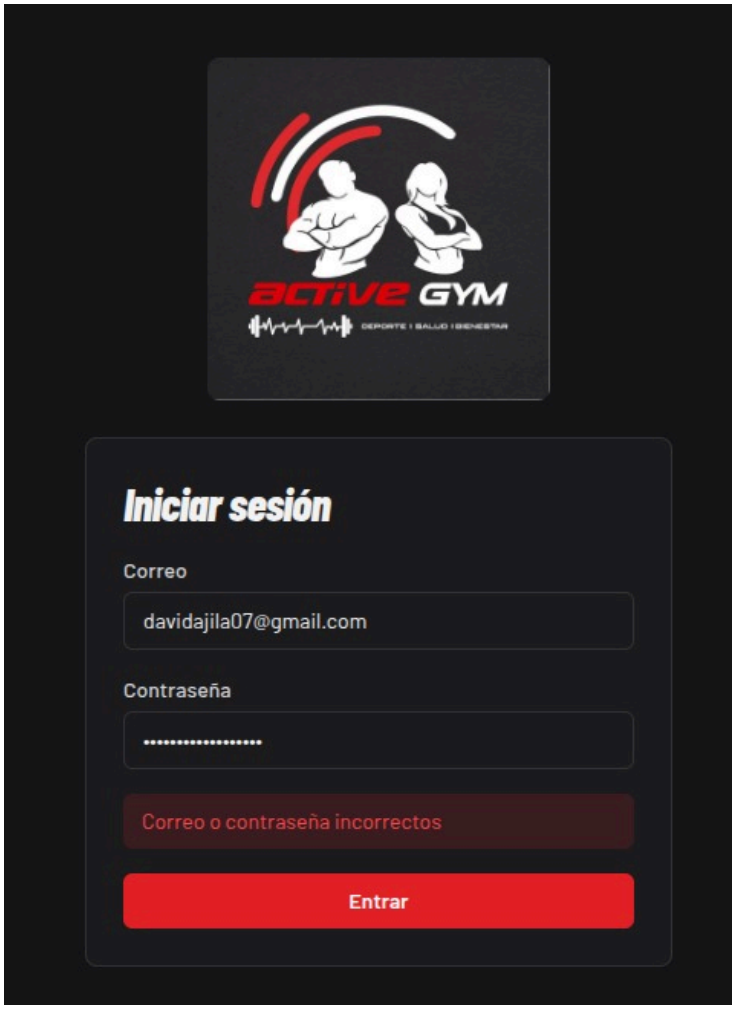
2. A07 — Fallos de autenticación

Objetivo: verificar que el sistema controle correctamente el inicio y cierre de sesión.

Prueba: ingresar credenciales incorrectas y comprobar que no se permita entrar; después, cerrar sesión e intentar reutilizar la sesión anterior.

Resultado esperado: el acceso se rechaza y la sesión cerrada deja de ser válida.

Credenciales incorrectas



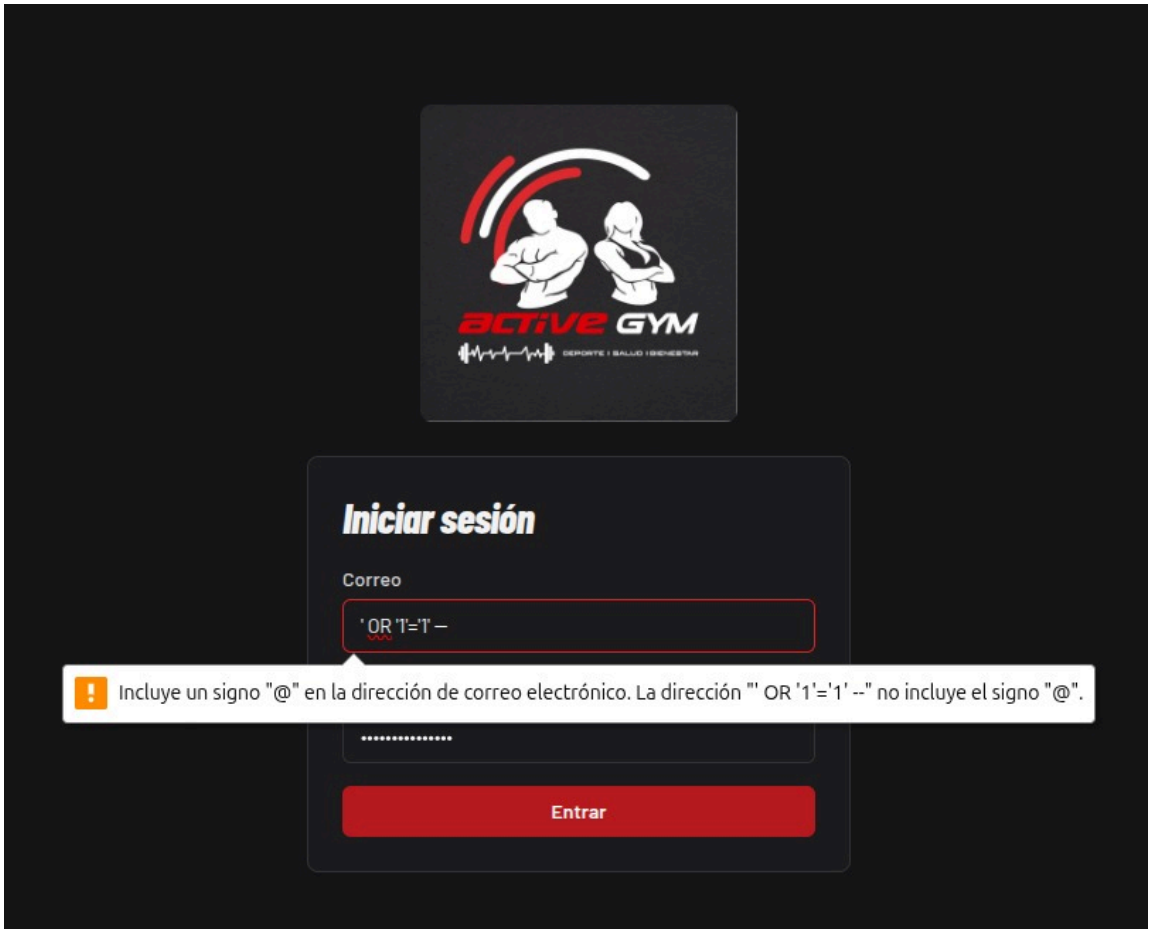
3. A05 — Injection

Objetivo: comprobar que las entradas no se interpreten como instrucciones maliciosas.

Prueba: introducir caracteres especiales y cadenas de prueba controladas en formularios de búsqueda o inicio de sesión.

Resultado esperado: el sistema trata las entradas como datos, sin alterar consultas ni ejecutar instrucciones no autorizadas.

Se realizó una prueba de inyección SQL en el inicio de sesión de Active Gym. El navegador rechazó la entrada por no cumplir con el formato de correo electrónico, impidiendo comprobar la respuesta del servidor ante esta prueba.



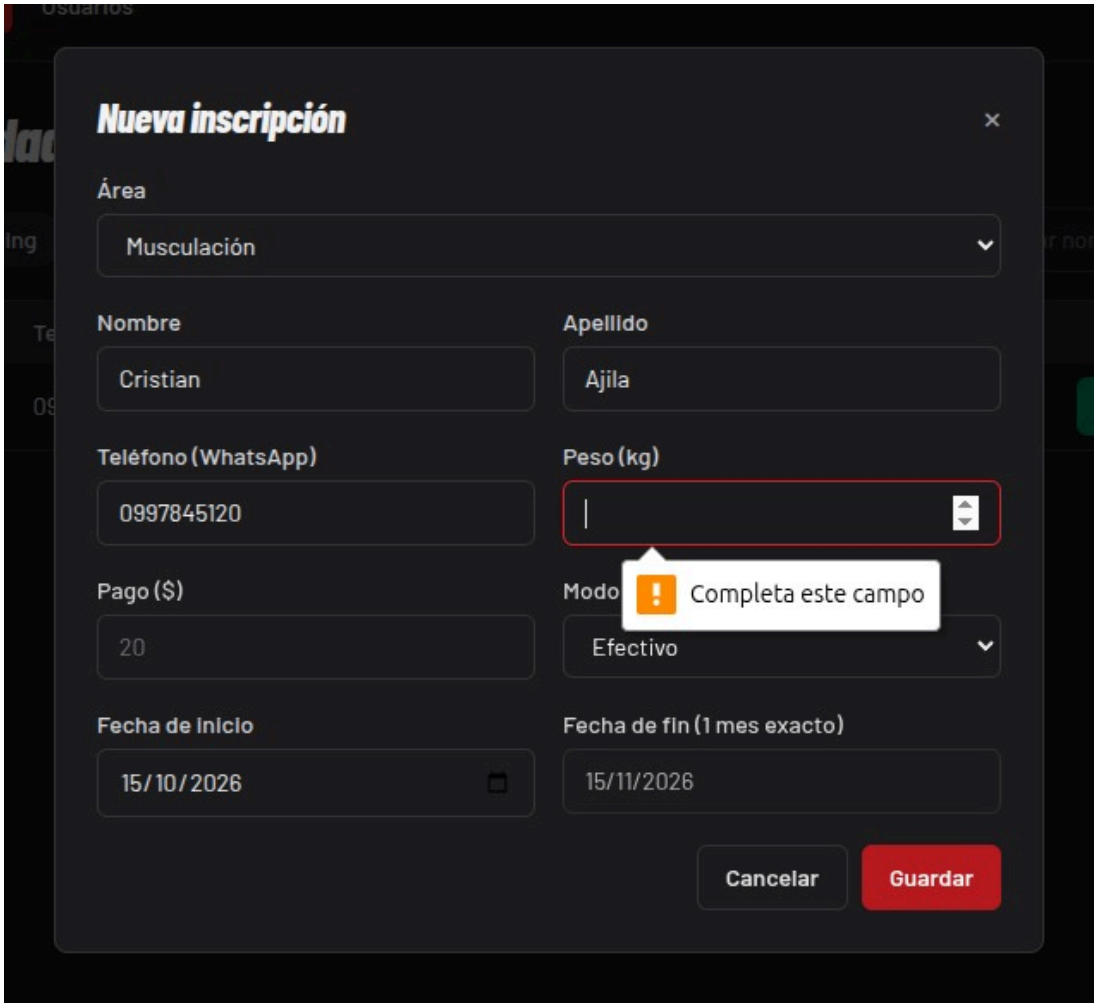
4. A02 — Configuración de seguridad incorrecta

Objetivo: detectar configuraciones que puedan exponer información o facilitar ataques.

Prueba: provocar un error controlado y revisar si aparecen rutas internas, trazas técnicas, credenciales u otros datos sensibles.

Resultado esperado: se presenta un mensaje genérico y no se expone información interna.

Se realizó una prueba de validación en el formulario de inscripción de Active Gym. Al dejar vacío el campo obligatorio «Peso (kg)», el sistema mostró una advertencia que impidió continuar con el registro sin completar el dato.



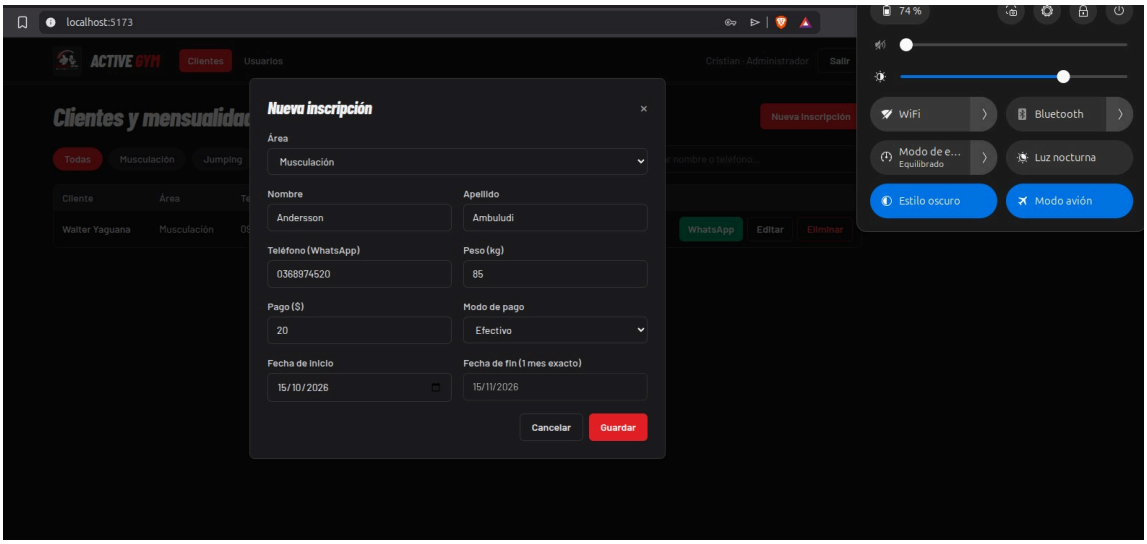
5. A10 — Gestión incorrecta de condiciones excepcionales

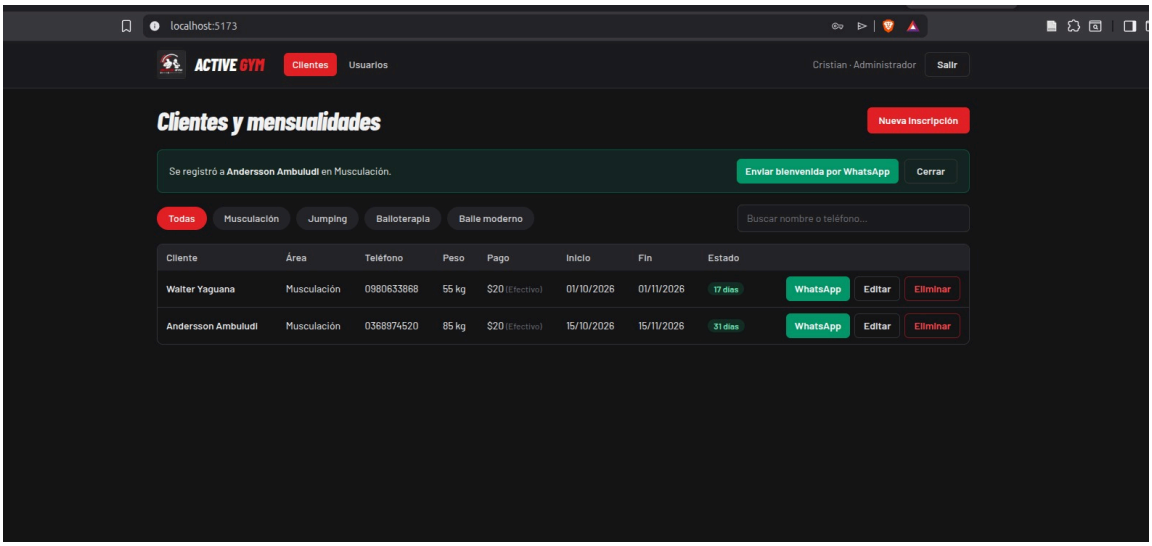
Objetivo: comprobar que el sistema gestione de forma segura los errores inesperados durante las operaciones.

Prueba: simular una interrupción de la conexión con el servidor al guardar una inscripción y verificar la respuesta del sistema.

Resultado esperado: el sistema informa del error de forma controlada, evita registrar datos incompletos o duplicados y permite continuar utilizando la aplicación.

Se realizó una prueba de gestión de condiciones excepcionales en Active Gym, desconectando la conexión Wi-Fi durante el registro de una inscripción. Se comprobó que el sistema guardó correctamente la información y continuó funcionando con normalidad.





Sesión 2 (viernes 16 de octubre, 07h30 a 09h30): Clasificación y corrección

Actividad 1: Buenas prácticas de gestión de errores (15 minutos)

Revisión de las buenas prácticas del desarrollo seguro: mensajes genéricos orientados al usuario, registro detallado en el servidor (logs) y deshabilitación del modo de depuración en producción.

Actividad 2: Clasificación y corrección de fugas (85 minutos)

Las parejas clasifican la severidad de cada fuga detectada y redactan la versión corregida del mensaje correspondiente; cuando el código de la aplicación está disponible, implementan la corrección en el componente respectivo y documentan el cambio realizado.

Actividad 3: Informe de la fase (20 minutos)

Redacción del informe de gestión de errores y carga de las evidencias en el repositorio del proyecto.

Clasificación y corrección de errores de seguridad
1. Buenas prácticas de gestión de errores

Se revisaron las buenas prácticas de gestión de errores aplicables al sistema Active Gym, considerando el uso de mensajes genéricos para los usuarios, el registro de errores técnicos en logs y la protección de información sensible. Debido a que el sistema se encuentra en desarrollo, se considera importante verificar que los mensajes de error no expongan información interna y que la configuración de depuración se ajuste al entorno de ejecución.

2. Clasificación de hallazgos por severidad y criticidad

Se analizaron los resultados obtenidos durante las cinco pruebas de seguridad realizadas en Active Gym, con el propósito de identificar posibles problemas y establecer acciones correctivas.

ID	Vulnerabilidad evaluada	Resultado obtenido	Severidad	Criticidad
A01	Control de acceso roto	El entrenador intentó acceder al panel de usuarios, pero el sistema lo redirigió a su panel correspondiente.	Baja	Baja
A07	Fallos de autenticación	Al ingresar credenciales incorrectas, el sistema rechazó el acceso y mostró el mensaje «Correo o contraseña incorrectos».	Baja	Baja
A05	Inyección	Se realizaron varias pruebas de inyección SQL en el inicio de sesión, pero no se consiguió acceder al sistema.	Baja	Baja

A02	Configuración de seguridad incorrecta	Al dejar vacío el campo Peso (kg), el formulario mostró una advertencia e impidió continuar con el registro.	Baja	Baja
A10	Gestión incorrecta de condiciones excepcionales	Se desconectó el Wi-Fi durante el registro, luego se restableció la conexión y se pulsó Guardar. La inscripción se guardó correctamente.	Baja	Baja

3. Propuesta de corrección de mensajes de error

Como parte de las buenas prácticas de desarrollo seguro, se proponen mensajes claros que permitan informar al usuario sin revelar detalles técnicos internos

Situación	Mensaje recomendado
Credenciales incorrectas	Correo o contraseña incorrectos.
Error al guardar una inscripción	No se pudo guardar la inscripción. Inténtalo nuevamente.
Página no encontrada	La página solicitada no está disponible.
Error inesperado	Ocurrió un error inesperado. Inténtalo más tarde.

Fase 4 (Semana 4 - del 19 al 23 de octubre de 2026): Mapeo OWASP Top 10 y priorización de hallazgos

Sesión 1 (jueves 22 de octubre, 09h30 a 11h30): Lista de cotejo OWASP

Actividad 1: Repaso del OWASP Top 10 (25 minutos)

Repaso de las diez categorías de riesgo con ejemplos de cada una, con énfasis en las categorías tratadas durante la semana: XSS, CSRF y exposición de datos.

Actividad 2: Aplicación de la lista de cotejo (75 minutos)

Laboratorio guiado: aplicación de la lista de cotejo OWASP Top 10 sobre la aplicación (mecanismos de sesión, tokens CSRF, cabeceras de seguridad, políticas de contraseñas, exposición de datos y componentes con vulnerabilidades conocidas), registrando la evidencia de cada ítem verificado.

Actividad 3: Registro de evidencias (20 minutos)

Sistematización de los resultados por categoría en la plantilla de la guía, con la conclusión fundamentada de cada una.

Sesión 2 (viernes 23 de octubre, 07h30 a 09h30): Priorización y cierre de la guía

Actividad 1: Matriz de priorización (20 minutos)

Construcción de la matriz de impacto y probabilidad con los hallazgos de las cuatro fases y selección de los tres hallazgos más relevantes del proyecto.

Actividad 2: Preparación del insumo para la guía APE 02 (70 minutos)

Completar la matriz con evidencias y estructurar la información que pasará a la auditoría técnica de la guía APE 02: criptografía, control de acceso e inyecciones. Cada pareja verifica que su repositorio contiene los entregables de las cuatro fases.

Actividad 3: Cierre y socialización (30 minutos)

Redacción del informe consolidado de la guía y socialización breve de los tres hallazgos prioritarios de cada pareja, con retroalimentación del docente y del curso.

6. Resultados esperados:

- Repositorio del proyecto en GitHub constituido, con la ficha del proyecto y el inventario de superficie de ataque con evidencias.

1. **Nombre del proyecto**
2. **Función del sistema**
3. **Estructura del proyecto**
4. **Módulos del sistemas**
5.

ActiveGym

2. Función del sistema

ActiveGym es un sistema web para la gestión administrativa de un gimnasio, que permite:

- Registrar y gestionar clientes inscritos en las diferentes áreas del gimnasio.
- Controlar mensualidades y fechas de vencimiento.
- Gestionar los usuarios del sistema, correspondientes a administradores y entrenadores.
- Generar alertas automáticas sobre mensualidades próximas a vencer.
- Enviar mensajes de WhatsApp a los clientes.

- Generar reportes y listados por área del gimnasio.

- Matriz de activos y amenazas clasificada según la tríada CIA, con controles propuestos para los activos críticos.
- Informe de gestión de errores con las fugas documentadas, su severidad clasificada y las correcciones propuestas.
- Lista de cotejo OWASP Top 10 completada con evidencias y matriz de priorización de los hallazgos del proyecto.
- Línea base del proyecto de seguridad consolidada, primer componente del portafolio que sustentará la defensa final de la semana 16.

7. Preguntas de Control:

1. La superficie de ataque de una aplicación web no se limita a sus páginas visibles: incluye formularios, parámetros, cabeceras y componentes de terceros. ¿Por qué un inventario exhaustivo de la superficie de ataque constituye el punto de partida de cualquier auditoría de seguridad, y qué riesgos implica omitir un componente del inventario?
2. Al clasificar los activos con la tríada CIA, un mismo activo puede exigir controles distintos para la confidencialidad, la integridad y la disponibilidad. ¿Cómo determinaría usted qué pilar priorizar cuando los recursos son limitados? Justifique su respuesta con un ejemplo de su propio proyecto.
3. Los mensajes de error detallados facilitan la depuración durante el desarrollo, pero constituyen una fuga de información en producción. ¿Qué prácticas permiten conciliar ambas necesidades, y qué información concreta no debería revelar jamás un mensaje de error dirigido al usuario final?
4. El OWASP Top 10 es un documento de concientización, no un estándar de verificación. ¿Qué relación existe entre sus diez categorías de riesgo y las vulnerabilidades concretas observadas en su aplicación, y por qué la priorización de hallazgos debe considerar el impacto y la probabilidad, y no únicamente la severidad técnica?

8. Evaluación:

Rúbrica de Evaluación (10 puntos)

Criterio	Excelente (2.5)	Bueno (1.5)	Regular (0.5)	Deficiente (0)
1. Selección y alcance del proyecto (Fase 1)	La aplicación seleccionada cumple todos los requisitos, ejecuta localmente y el repositorio con la ficha y el inventario de superficie de ataque está completo y organizado.	La aplicación cumple los requisitos con observaciones menores; repositorio completo con detalles de forma pendientes.	Aplicación con requisitos parciales o inventario con menos de cinco elementos documentados.	Sin aplicación funcional o sin repositorio de evidencias.
2. Tríada CIA y matriz de activos (Fase 2)	Matriz con seis o más activos, clasificación CIA correcta por activo y controles coherentes con las amenazas identificadas.	Matriz completa con observaciones menores de clasificación o de controles.	Matriz con menos de cuatro activos o clasificación confusa entre los pilares.	Sin matriz de activos o sin clasificación CIA.
3. Gestión de errores (Fase 3)	Cinco o más fugas documentadas con evidencia, severidad clasificada y correcciones conforme a las buenas prácticas.	Tres o cuatro fugas documentadas o correcciones genéricas.	Menos de tres fugas documentadas o evidencias incompletas.	Sin informe de gestión de errores.
4. Mapeo OWASP Top 10 (Fase 4)	Lista de cotejo completa con conclusión fundamentada por categoría y matriz de priorización justificada.	Lista con vacíos menores de verificación o priorización poco justificada.	Lista parcial o sin evidencias de verificación.	Sin lista de cotejo ni matriz de priorización.
5. Documentación, evidencias y ética	Evidencias claras y trazables en el repositorio; trabajo realizado	Evidencias con observaciones de formato; cumplimiento de	Evidencias insuficientes o desordenadas.	Evidencias ausentes o prácticas fuera del entorno

	exclusivamente en el entorno propio o controlado.	las reglas éticas del laboratorio.		autorizado.

Nota: La Actividad Práctico–Experimental podrá ser utilizada por el docente con carácter demostrativo. En tal caso, tanto la calificación como la entrega del Reporte Técnico por parte de los estudiantes pueden ser opcionales.

9. Bibliografía:

- Haz Lopez, L. V., et al. (2024). Hacking Ética: Teoría y Prácticas. CID. ISBN: 978-1-967344-23-9.
- Vega Briceño, E. (2021). Seguridad de la Información. Editorial Área de Innovación y Desarrollo. ISBN: 978-84-122093-6-5.
- Whitman, M. E., & Mattord, H. J. (2018). Management of Information Security (6th ed.). Cengage Learning.

- OWASP Foundation. (2025). OWASP Top 10. Recuperado de https://owasp.org/Top10/
- Howard, M., & LeBlanc, D. (2003). Writing Secure Code (2nd ed.). Microsoft Press.

10. Elaboración y Aprobación:

Elaborado por	Valeria Herrera Salazar **Docente**	Validar únicamente en FirmaEC. Firmado electrónicamente por: **VALERIA DEL ROSARIO HERRERA SALAZAR**
Revisado por *Solo si es realizado en laboratorios*	**Técnico Docente**	
Aprobado por	Edison L. Coronel Romero **Director de Carrera**	

O